Безопасность в SQL Server: права доступа

Предметная область: студенты, заказы и сотрудники. **СУБД:** Microsoft SQL Server 2025 (17.0.1000.7), SSMS 22. **Имя БД:** MyDB. **Скрипты:** `скрипты/4_10/01_setup.sql`, `02_objects.sql`, `03_tests.sql`.

Цель работы

Научиться управлять правами доступа к таблицам, создавать пользователей и представления для ограничения доступа, проверять права через выполнение операций и объяснять результат.

Подготовка

Таблицы Groups, Students, Orders, Employees и тестовые данные взяты из задания. Пользователи Reader и Writer созданы как `WITHOUT LOGIN`, проверка идёт через `EXECUTE AS USER`. Представления StudentsPublic, EmployeesPublic и MyOrders созданы в `02_objects.sql`.

Ожидаемые ошибки перехвачены через `TRY/CATCH` и выведены строкой с меткой теста. Снимки сделаны в режиме Results to Text, потому что в сетке текст ошибки обрезается. Интерфейс SSMS русский, поэтому сообщения на русском: они соответствуют английским текстам из задания.

Отличия от текста задания

При точном выполнении задания часть ожидаемых результатов не получается. Сделанные изменения:

Место	Проблема	Что сделано
Все даты Orders	Логин с русским языком читает `'2025-08-03'` как 8 марта	Даты записаны как `'20250803'`
Задача 2	У Reader осталось право SELECT на Students из задачи 1, ошибки бы не было	Добавлен `REVOKE SELECT ON Students FROM Reader`
Задача 3	Заказ 100 уже есть, INSERT падает с ошибкой 2627	Перед тестом заказ 100 удалён от имени dbo
Задача 3	У Writer нет SELECT, поэтому проверка записи от его имени упала бы, а в задаче 7 этот запрет обязателен	Проверочный SELECT выполнен от dbo после `REVERT`
Задачи 3, 4, 8	`WHERE OrderID = 100` требует права SELECT на OrderID. Без него вместо ожидаемой ошибки приходит ошибка про SELECT, а UPDATE Status не выполняется	На время этих тестов выдан `GRANT SELECT (OrderID)`, затем `REVOKE`
Задача 6	`CREATE PROCEDURE` должен быть первым в батче, иначе ошибка 111, а не проверка прав	Создание запущено через `EXEC (N'...')` внутри TRY

Задача 1. Пользователи Reader и Writer

Reader получает только SELECT на Students, Writer только INSERT.

Код

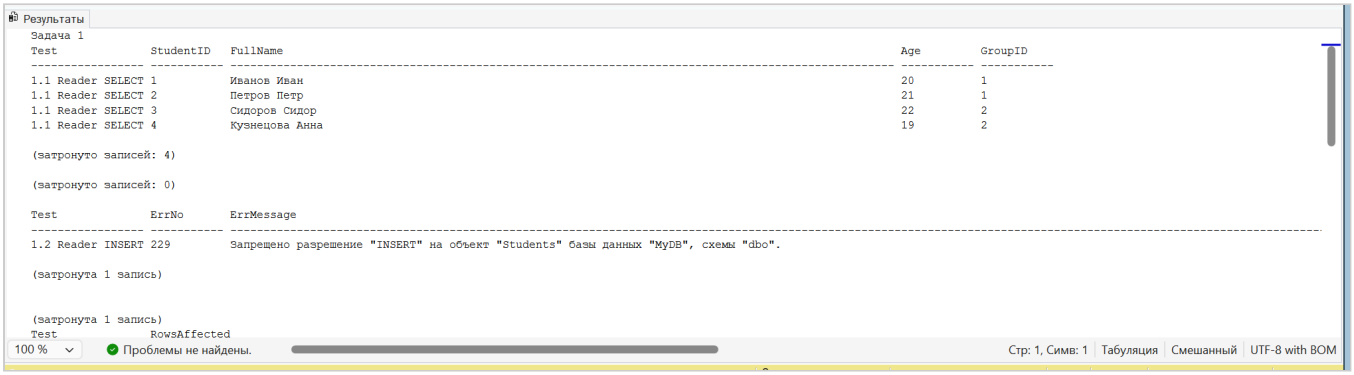
```
PRINT N'Задача 1';
GRANT SELECT ON Students TO Reader;
GRANT INSERT ON Students TO Writer;
GO
```

Тест

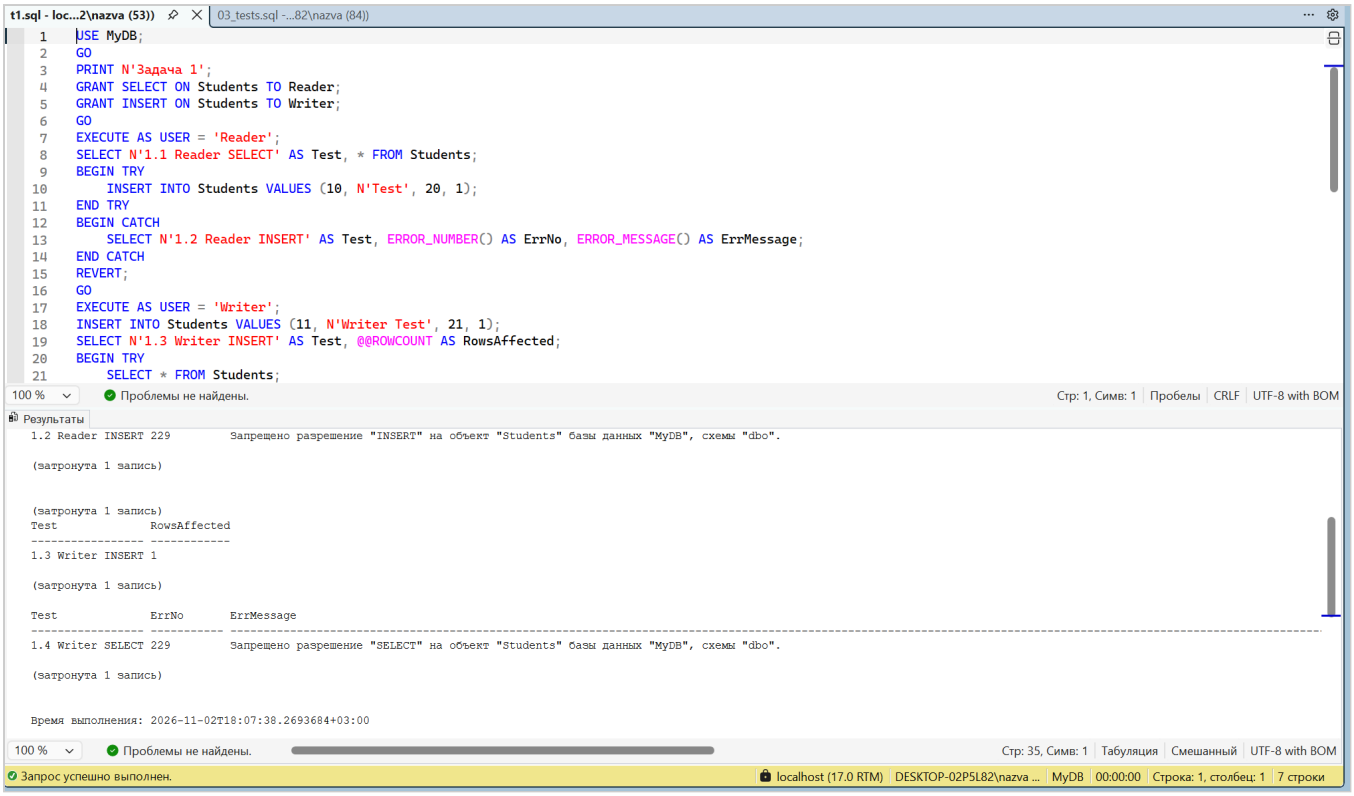
```
EXECUTE AS USER = 'Reader';
SELECT N'1.1 Reader SELECT' AS Test, * FROM Students;
BEGIN TRY
    INSERT INTO Students VALUES (10, N'Test', 20, 1);
END TRY
BEGIN CATCH
    SELECT N'1.2 Reader INSERT' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
REVERT;
GO
EXECUTE AS USER = 'Writer';
INSERT INTO Students VALUES (11, N'Writer Test', 21, 1);
SELECT N'1.3 Writer INSERT' AS Test, @@ROWCOUNT AS RowsAffected;
BEGIN TRY
    SELECT * FROM Students;
END TRY
BEGIN CATCH
    SELECT N'1.4 Writer SELECT' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
REVERT;
GO
```

Результат. Reader прочитал 4 строки, его INSERT завершился ошибкой 229. Writer добавил 1 строку, его SELECT завершился ошибкой 229. Сервер проверяет каждое действие отдельно, поэтому одно право не даёт другого.

Скриншот 1. Reader: чтение таблицы и запрет INSERT.



Скриншот 2. Код задачи и результаты Writer.



Задача 2. Доступ через представление

Reader работает только с представлением StudentsPublic, где нет возраста.

Код

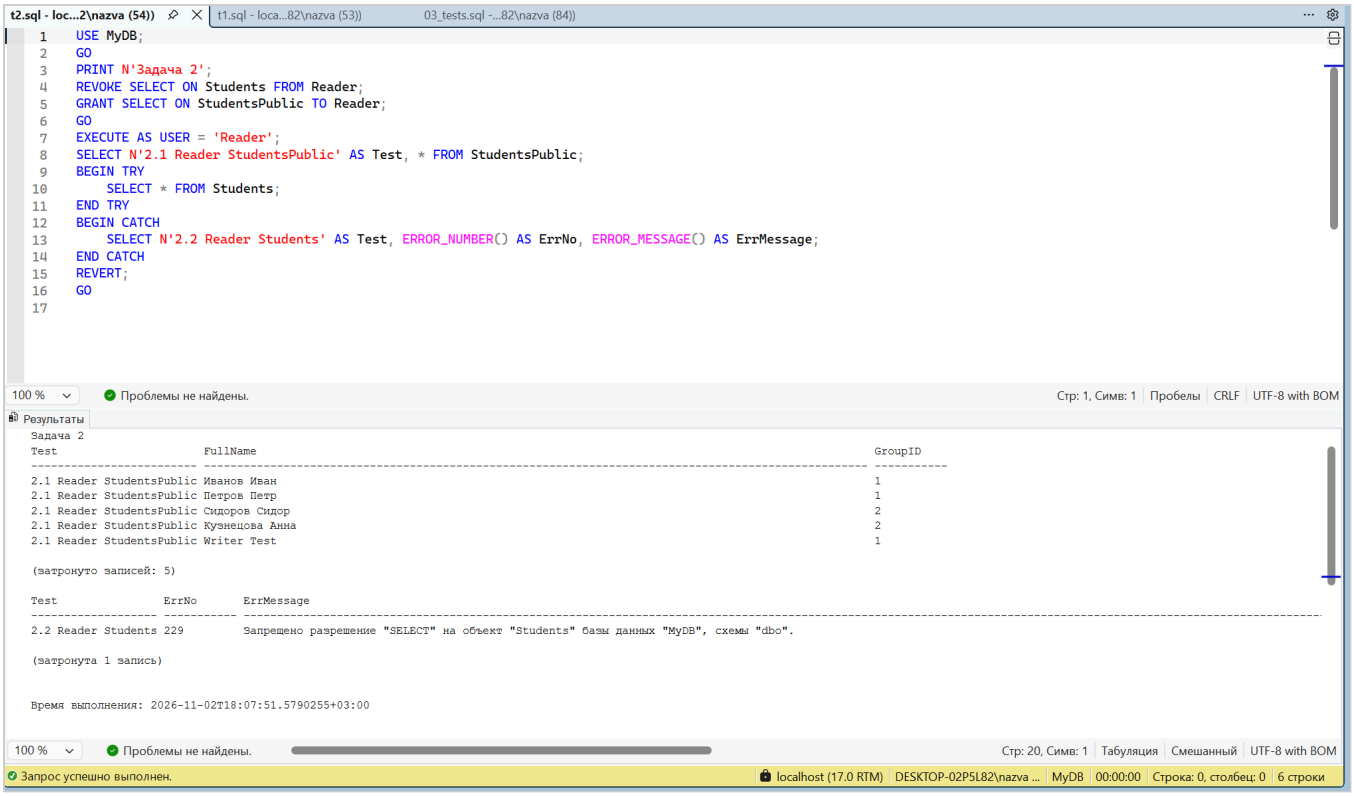
```
PRINT N'Задача 2';
REVOKE SELECT ON Students FROM Reader;
GRANT SELECT ON StudentsPublic TO Reader;
GO
```

Тест

```
EXECUTE AS USER = 'Reader';
SELECT N'2.1 Reader StudentsPublic' AS Test, * FROM StudentsPublic;
BEGIN TRY
    SELECT * FROM Students;
END TRY
BEGIN CATCH
    SELECT N'2.2 Reader Students' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
REVERT;
GO
```

Результат. StudentsPublic вернуло 5 строк с колонками FullName и GroupID (4 исходных и строка Writer Test из задачи 1). Прямой SELECT из Students завершился ошибкой 229. Представление работает, потому что и оно, и таблица принадлежат dbo: действует цепочка владения, и права на таблицу отдельно не проверяются.

Скриншот 3. Данные представления и запрет на таблицу.



Задача 3. Запрет удаления заказов

Writer может добавлять заказы, но не удалять.

Код

```
PRINT N'Задача 3';
DELETE FROM Orders WHERE OrderID = 100;
GRANT INSERT ON Orders TO Writer;
DENY DELETE ON Orders TO Writer;
GO
```

Тест

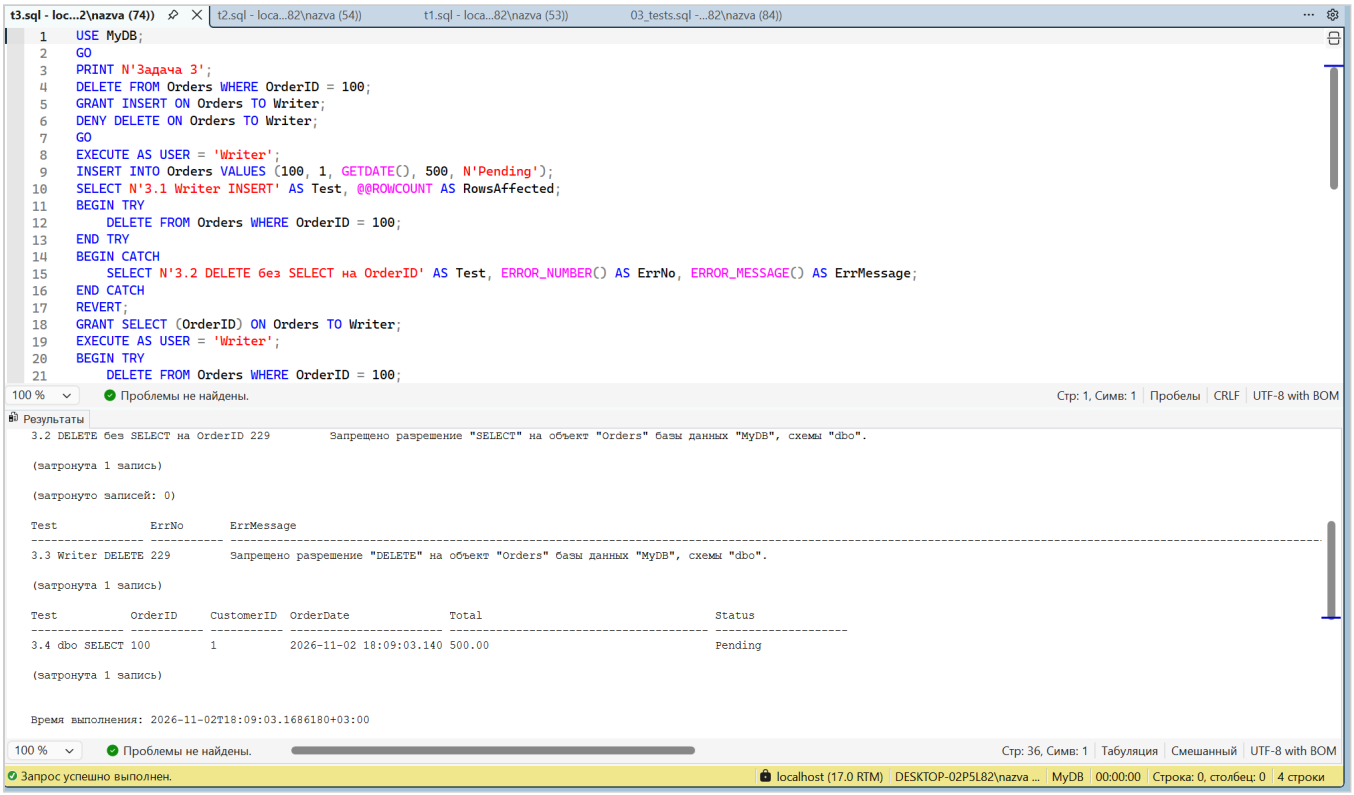
```
EXECUTE AS USER = 'Writer';
INSERT INTO Orders VALUES (100, 1, GETDATE(), 500, N'Pending');
SELECT N'3.1 Writer INSERT' AS Test, @@ROWCOUNT AS RowsAffected;
BEGIN TRY
    DELETE FROM Orders WHERE OrderID = 100;
END TRY
BEGIN CATCH
    SELECT N'3.2 DELETE без SELECT на OrderID' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS
ErrMessage;
END CATCH
REVERT;
GRANT SELECT (OrderID) ON Orders TO Writer;
EXECUTE AS USER = 'Writer';
BEGIN TRY
    DELETE FROM Orders WHERE OrderID = 100;
END TRY
BEGIN CATCH
    SELECT N'3.3 Writer DELETE' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
REVERT;
SELECT N'3.4 dbo SELECT' AS Test, * FROM Orders WHERE OrderID = 100;
GO
```

Результат. INSERT затронул 1 строку. Без права SELECT на OrderID запрос DELETE дал ошибку 229 про SELECT (тест 3.2). С этим правом DELETE дал ожидаемую ошибку 229 про DELETE (тест 3.3). Заказ 100 остался в таблице: Total = 500.00, Status = Pending. `DENY` сильнее `GRANT`, поэтому удаление запрещено явно.

Скриншот 4. Вставка и первая ошибка DELETE.



Скриншот 5. Ошибка про DELETE и запись 100, оставшаяся в таблице.



Задача 4. Обновление только статуса

Право UPDATE выдано только на колонку Status.

Код

```
PRINT N'Задача 4';
GRANT UPDATE (Status) ON Orders TO Writer;
GO
```

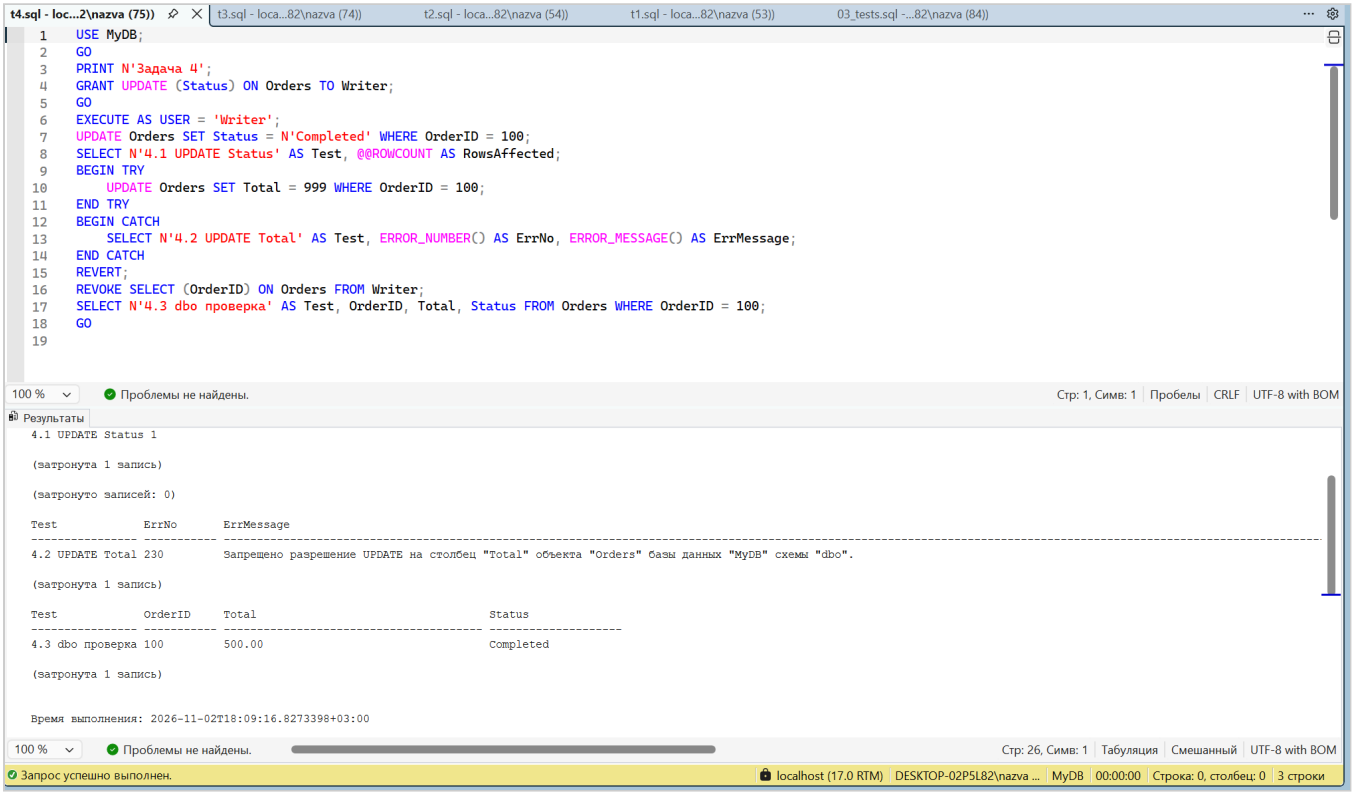
Тест

```
EXECUTE AS USER = 'Writer';
UPDATE Orders SET Status = N'Completed' WHERE OrderID = 100;
SELECT N'4.1 UPDATE Status' AS Test, @@ROWCOUNT AS RowsAffected;
```

```
BEGIN TRY
    UPDATE Orders SET Total = 999 WHERE OrderID = 100;
END TRY
BEGIN CATCH
    SELECT N'4.2 UPDATE Total' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
REVERT;
REVOKE SELECT (OrderID) ON Orders FROM Writer;
SELECT N'4.3 dbo проверка' AS Test, OrderID, Total, Status FROM Orders WHERE OrderID = 100;
GO
```

Результат. UPDATE Status затронул 1 строку. UPDATE Total завершился ошибкой 230 на столбец Total. Проверка показала: Total = 500.00, Status = Completed. Права на уровне колонок разрешают менять только указанные поля.

Скриншот 6. Статус изменён, изменение суммы запрещено.



Задача 5. Скрытие зарплат

Reader работает с EmployeesPublic, где нет колонки Salary.

Код

```
PRINT N'Задача 5';
GRANT SELECT ON EmployeesPublic TO Reader;
GO
```

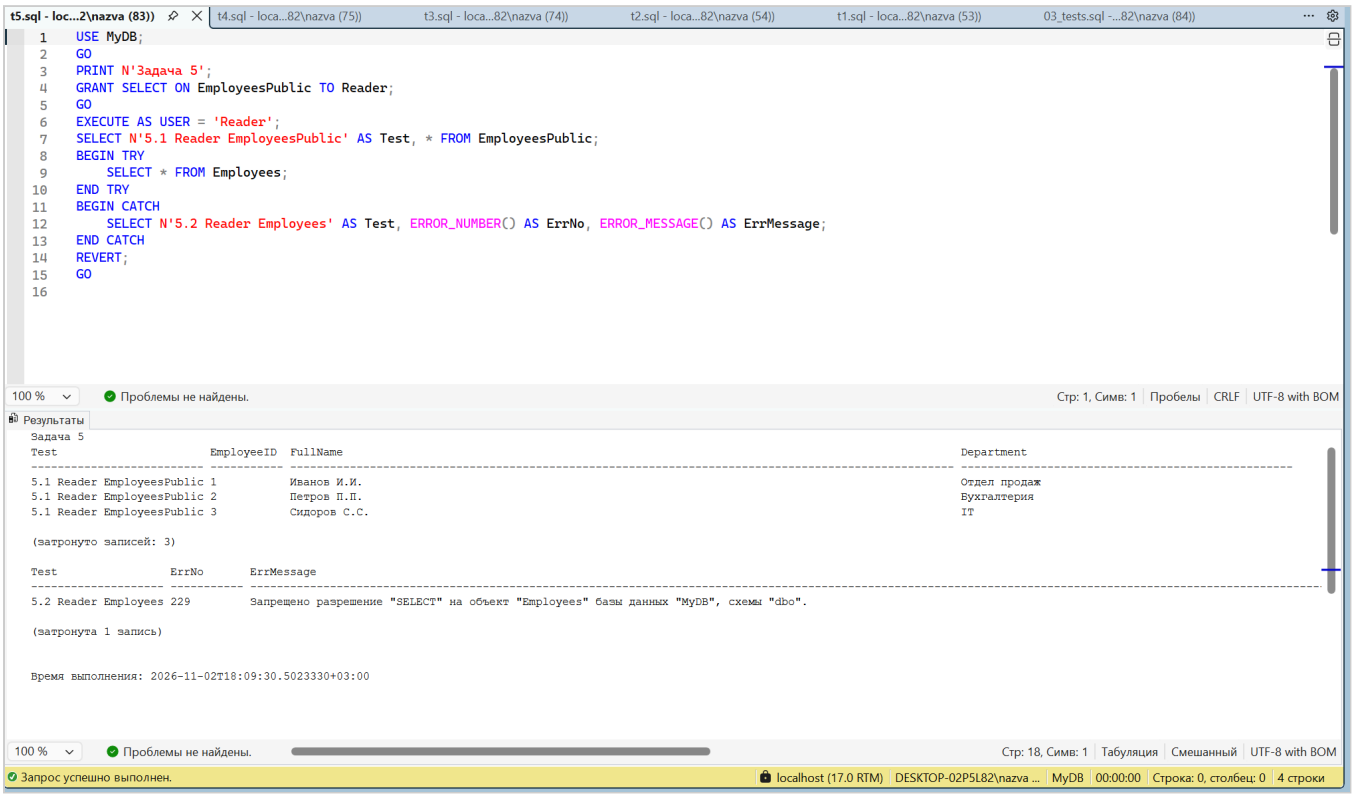
Тест

```
EXECUTE AS USER = 'Reader';
SELECT N'5.1 Reader EmployeesPublic' AS Test, * FROM EmployeesPublic;
BEGIN TRY
    SELECT * FROM Employees;
END TRY
BEGIN CATCH
    SELECT N'5.2 Reader Employees' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
```

```
REVERT;
GO
```

Результат. Представление вернуло 3 сотрудников без Salary. SELECT из Employees завершился ошибкой 229. Зарплаты недоступны Reader напрямую.

Скриншот 7. Сотрудники без зарплаты и запрет на таблицу.



Задача 6. Попытка эскалации прав

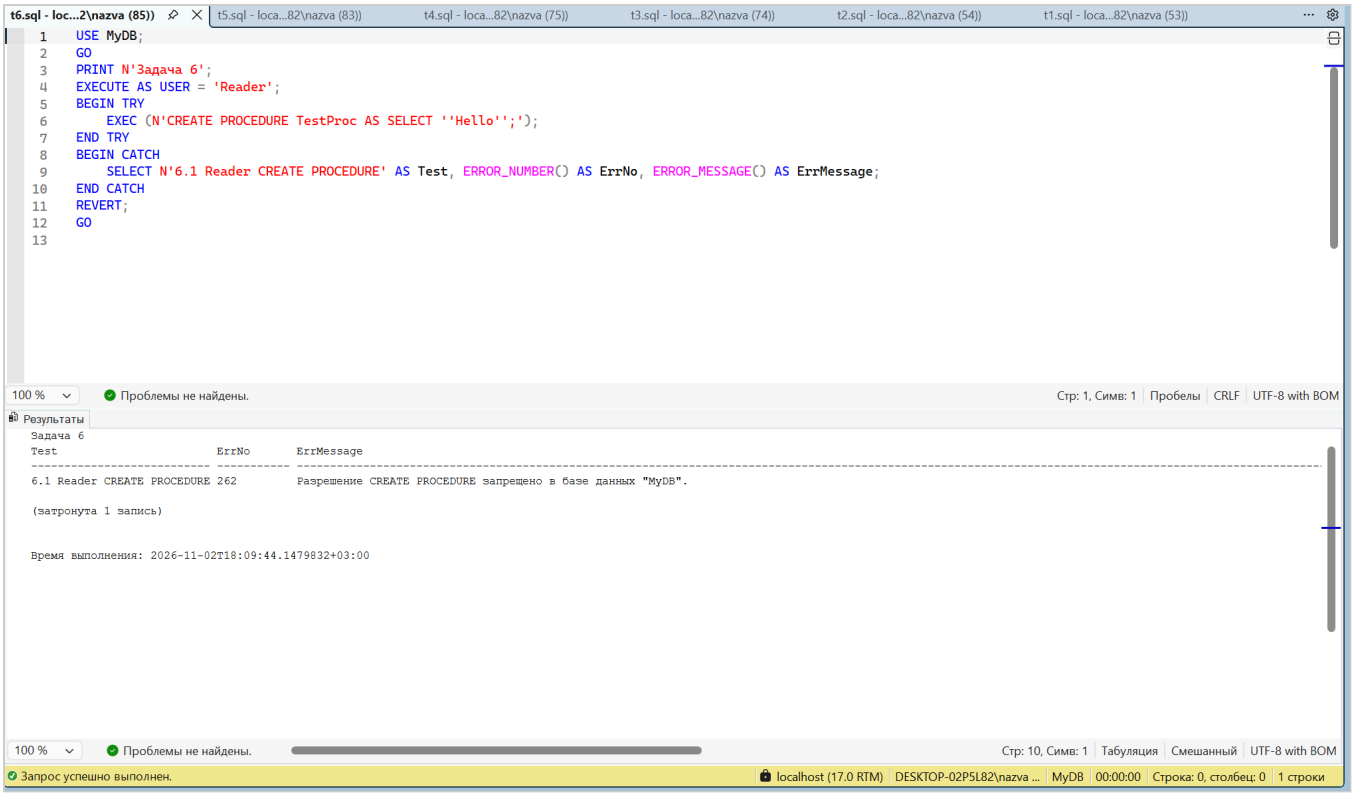
Проверка, что Reader не может создать процедуру.

Тест

```
PRINT N'Задача 6';
EXECUTE AS USER = 'Reader';
BEGIN TRY
    EXEC (N'CREATE PROCEDURE TestProc AS SELECT ''Hello'';');
END TRY
BEGIN CATCH
    SELECT N'6.1 Reader CREATE PROCEDURE' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
REVERT;
GO
```

Результат. Ошибка 262: разрешение CREATE PROCEDURE запрещено в базе данных MyDB. Создание объектов требует отдельного права, поэтому пользователь с правом чтения не может расширить свои возможности через собственный код.

Скриншот 8. Запрет создания процедуры.



Задача 7. Только свои заказы

Writer работает через MyOrders, где отобраны заказы CustomerID = 1.

Код

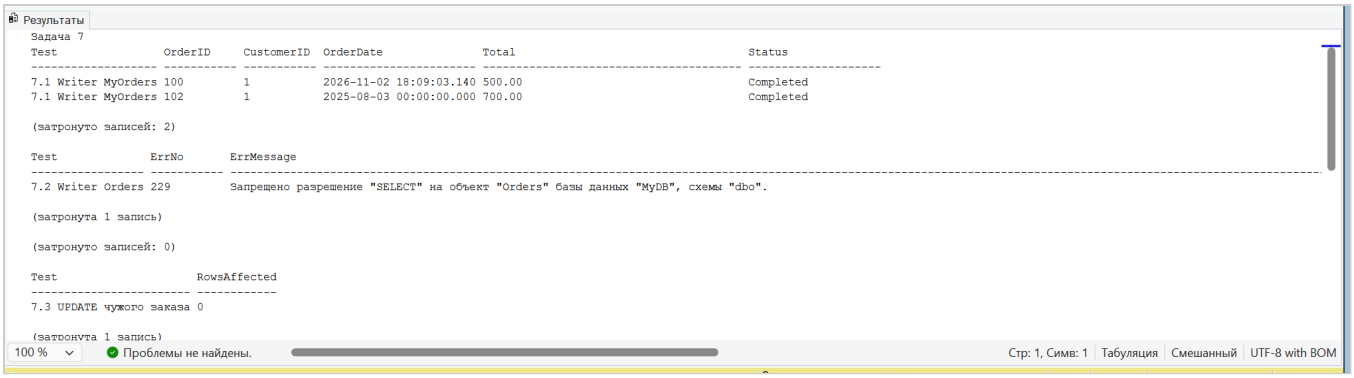
```
PRINT N'Задача 7';
GRANT SELECT, UPDATE ON MyOrders TO Writer;
GO
```

Тест

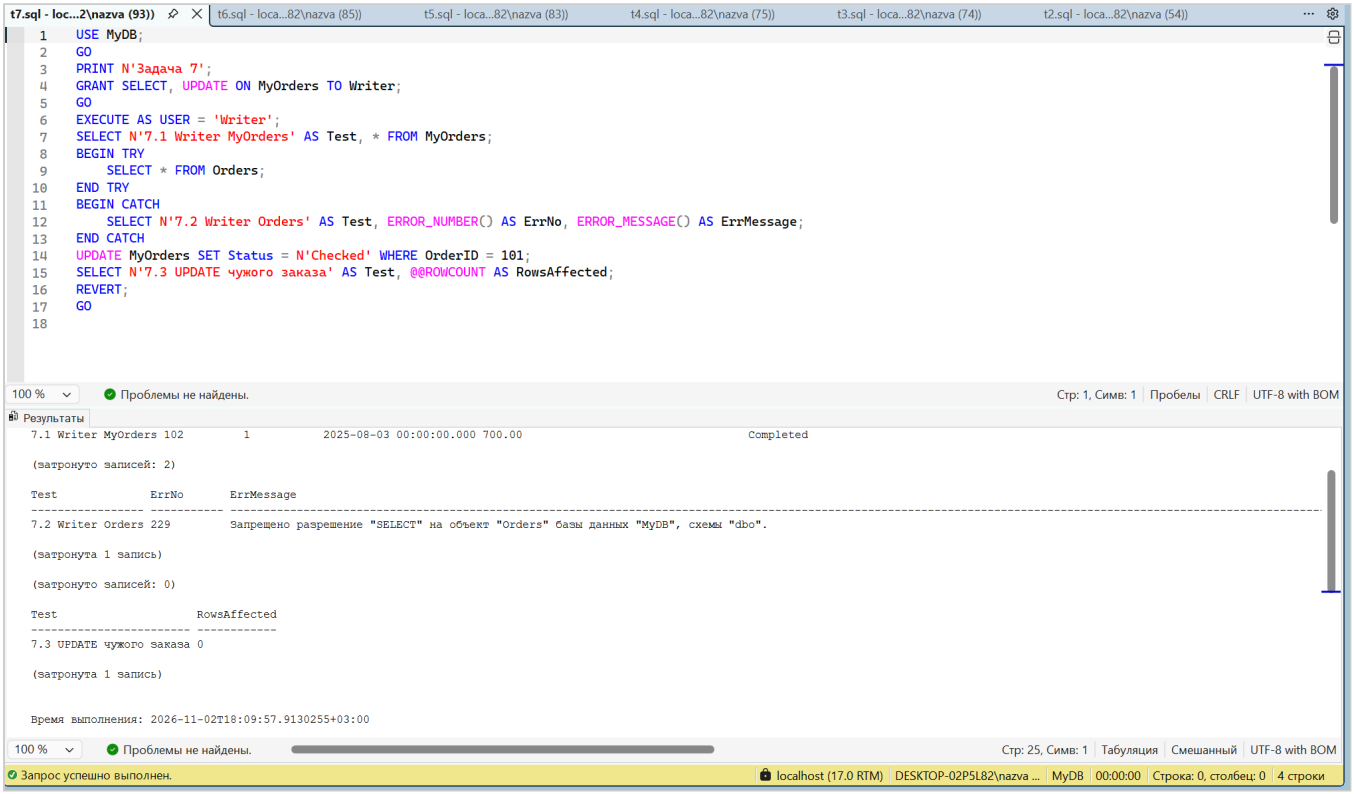
```
EXECUTE AS USER = 'Writer';
SELECT N'7.1 Writer MyOrders' AS Test, * FROM MyOrders;
BEGIN TRY
    SELECT * FROM Orders;
END TRY
BEGIN CATCH
    SELECT N'7.2 Writer Orders' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
UPDATE MyOrders SET Status = N'Checked' WHERE OrderID = 101;
SELECT N'7.3 UPDATE чужого заказа' AS Test, @@ROWCOUNT AS RowsAffected;
REVERT;
GO
```

Результат. MyOrders вернуло 2 заказа (100 и 102) с CustomerID = 1. SELECT из Orders завершился ошибкой 229. Дополнительный тест 7.3: попытка изменить через представление чужой заказ 101 затронула 0 строк, потому что он не попадает в фильтр.

Скриншот 9. Только заказы клиента 1 и запрет на таблицу.



Скриншот 10. Код задачи и нулевое изменение чужого заказа.



Задача 8. Откат при нарушении прав

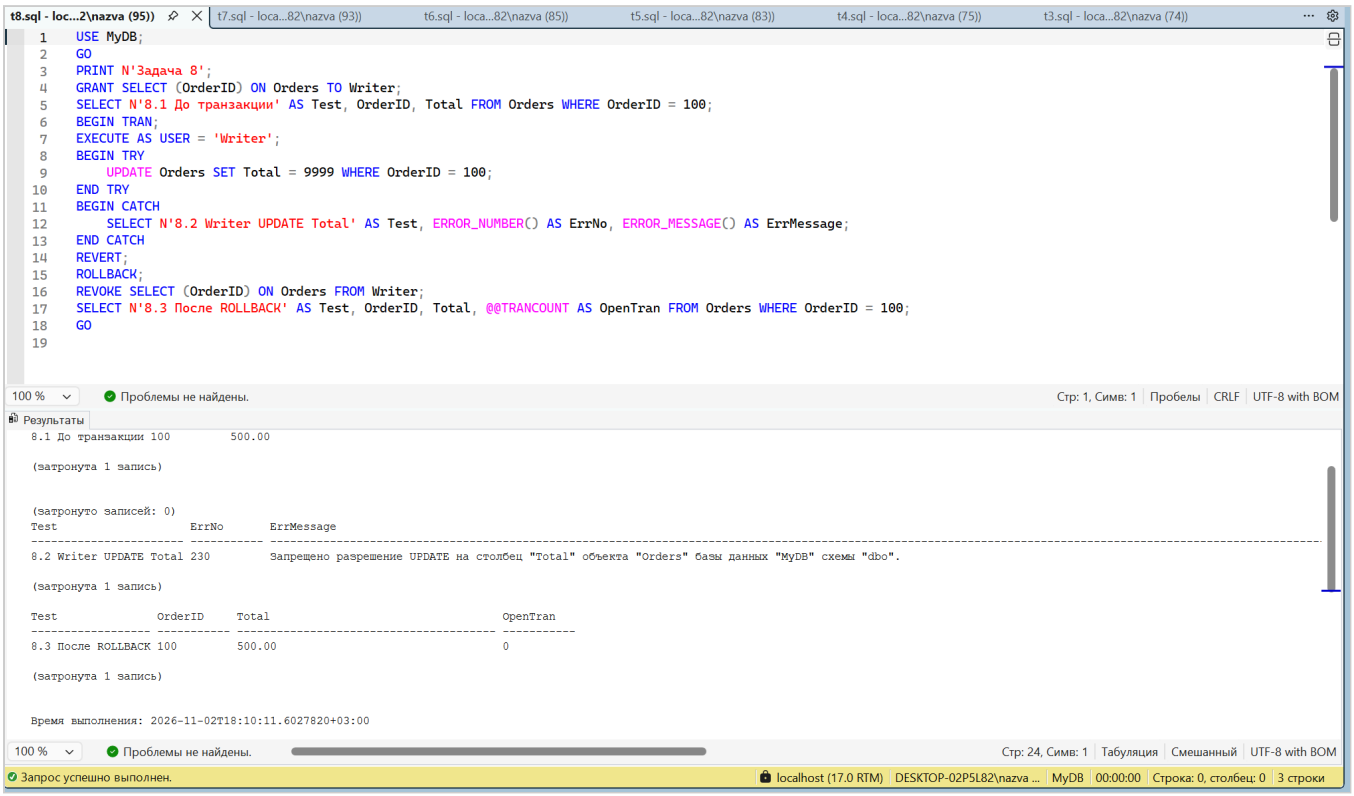
Writer пытается изменить Total внутри транзакции.

Тест

```
PRINT N'Задача 8';
GRANT SELECT (OrderID) ON Orders TO Writer;
SELECT N'8.1 До транзакции' AS Test, OrderID, Total FROM Orders WHERE OrderID = 100;
BEGIN TRAN;
EXECUTE AS USER = 'Writer';
BEGIN TRY
    UPDATE Orders SET Total = 9999 WHERE OrderID = 100;
END TRY
BEGIN CATCH
    SELECT N'8.2 Writer UPDATE Total' AS Test, ERROR_NUMBER() AS ErrNo, ERROR_MESSAGE() AS ErrMessage;
END CATCH
REVERT;
ROLLBACK;
REVOKE SELECT (OrderID) ON Orders FROM Writer;
SELECT N'8.3 После ROLLBACK' AS Test, OrderID, Total, @@TRANCOUNT AS OpenTran FROM Orders WHERE OrderID =
100;
GO
```

Результат. До транзакции Total = 500.00. UPDATE завершился ошибкой 230, после `ROLLBACK` значение осталось 500.00, открытых транзакций 0. Ошибка прав не откатывает транзакцию сама: её закрывает явный `ROLLBACK`, а изменений в данных не появляется.

Скриншот 11. Значение Total до и после отката.



Вывод

Все 8 задач дали ожидаемые результаты. Ошибка 229 означает запрет на объект, 230 запрет на колонку, 262 запрет на создание объекта. Минимальные права и представления скрывают чувствительные данные, а при выдаче прав важно учитывать, что `WHERE` тоже требует права SELECT на используемые колонки.